GUIA PRÁTICO · EDIÇÃO 2026



OPSEC
na internet

Do básico ao avançado: proteja suas contas, seus dados e a sua identidade

SENHAS · GOLPES · PRIVACIDADE · ANONIMATO

GUIA PRÁTICO

OPSEC na internet

Do básico ao avançado: proteja suas contas, seus dados e a sua identidade

OPSEC na internet
Do básico ao avançado: proteja suas contas, seus dados e a sua identidade

Edição de 2026. Ferramentas, serviços e configurações mudam com o tempo: confira sempre as informações atuais antes de tomar decisões importantes.

Este livro tem fins educativos e de autoproteção. Ele não substitui orientação jurídica nem o atendimento das autoridades em casos de crime.

Ilustrações e diagramas feitos para esta edição.

Sumário

Antes de começar 1

PARTE 1 · FUNDAMENTOS

1 O que é OPSEC 5

2 Seu modelo de ameaças 9

PARTE 2 · BÁSICO

3 Senhas que não te traem 14

4 Dois fatores: a segunda tranca 18

5 Golpes e engenharia social 22

6 Celular e computador em ordem 27

PARTE 3 · INTERMEDIÁRIO

7 Sua pegada digital 32

8 Navegar sem deixar rastro fácil 36

9 Mensagens e e-mail 41

PARTE 4 · AVANÇADO

10 Compartimentalização 47

11 Anonimato: Tor e Tails 51

12 Segurança física e em trânsito 55

PARTE 5 · NA PRÁTICA

13 Quando a OPSEC falhou 60

14 Plano de ação 64

Glossário 68

Antes de começar

Toda semana alguém perde o WhatsApp para um golpista, tem o Instagram sequestrado, vê o CPF circulando num painel de consulta ou descobre que uma foto postada "sem querer" mostrava a fachada de casa. Quase nunca é obra de um hacker genial. Na maioria das vezes, é uma sequência de pequenos descuidos que, somados, entregam exatamente o que um golpista precisava.

OPSEC (do inglês *Operations Security*, segurança operacional) é o hábito de enxergar essa soma antes que alguém de fora enxergue. Não é um programa que você instala nem uma configuração que você liga uma vez. É uma forma de pensar: *que informação minha tem valor, quem poderia querer, e por onde ela está vazando?*

Este livro foi escrito para quem usa a internet todos os dias e quer parar de ser alvo fácil. Ele começa do zero e termina em técnicas usadas por jornalistas, pesquisadores e pessoas que realmente precisam não ser encontradas.

Como o livro está organizado

Parte	O que você aprende	Para quem
1. Fundamentos	O que é OPSEC e como montar o seu modelo de ameaças	Todo mundo
2. Básico	Senhas, dois fatores, golpes, celular e computador	Todo mundo, já na primeira semana
3. Intermediário	Pegada digital, navegação, mensagens e e-mail	Quem quer reduzir rastros
4. Avançado	Compartimentalização, anonimato, segurança física	Quem tem motivo real para se esconder melhor
5. Na prática	Casos reais, plano de ação e o que fazer se der errado	Todo mundo

Você não precisa aplicar tudo. Na verdade, **não deveria**: segurança demais para o seu risco vira cansaço, e cansaço vira descuido. O Capítulo 2 ajuda a decidir até onde ir.

> **COMO LER**
>
> Leia as Partes 1 e 2 inteiras: elas resolvem a maior parte dos problemas do dia a dia. Depois, vá para os capítulos que fazem sentido para a sua realidade. No fim de cada capítulo há um **checklist** curto para você marcar o que já fez.

UM AVISO HONESTO

Nenhum método deixa ninguém 100% seguro ou 100% anônimo. O objetivo é tornar você **caro demais** para a maioria dos atacantes, que preferem alvos fáceis. As ferramentas citadas são exemplos que existiam quando este livro foi escrito; serviços mudam, então confira sempre a reputação atual antes de confiar em um.

Este é um material de **autoproteção**. As mesmas ideias que protegem você não servem de licença para invadir, perseguir ou enganar outras pessoas, e usar essas técnicas para cometer crimes não as torna menos crime.

PARTE 1

Fundamentos

CAPÍTULO 1

O que é OPSEC

Durante a Guerra do Vietnã, as forças americanas perceberam que o inimigo parecia saber, com antecedência, onde seriam os bombardeios. Não havia espião infiltrado nem código quebrado. Uma equipe chamada **Purple Dragon** investigou e descobriu que a informação vazava por detalhes sem importância aparente: horários de pedidos de combustível, rotas de aviões de apoio, avisos de espaço aéreo publicados para a aviação civil. Cada peça, sozinha, era inofensiva. Juntas, contavam a operação inteira.

Dessa investigação nasceu a ideia de **OPSEC**: proteger não só os segredos óbvios, mas também as migalhas que permitem a alguém *deduzir* os segredos.

A internet é feita de migalhas

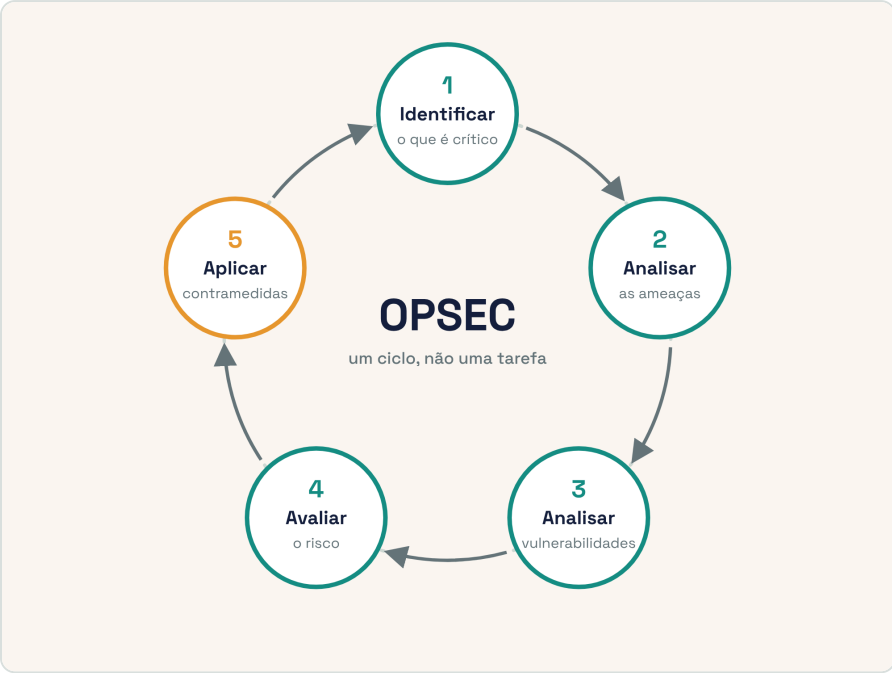
Hoje, as migalhas estão em todo lugar:

- a foto do almoço que mostra o crachá da empresa;
- o "parabéns!" público que revela sua data de nascimento;
- o story na academia, todo dia às 7h;
- o mesmo apelido usado no fórum de games e no LinkedIn;
- o e-mail pessoal cadastrado em dezenas de sites que um dia vazam.

Um golpista paciente junta essas peças da mesma forma que o inimigo no Vietnã: nome completo, cidade, família, rotina, operadora de celular, banco. Com isso, ele liga para a operadora fingindo ser você, ou manda ao seu pai uma mensagem convincente "do seu número novo".

O ciclo de OPSEC em cinco passos

O método clássico tem cinco passos, e eles servem tanto para um exército quanto para uma pessoa comum.



O ciclo de OPSEC: um processo que se repete, não uma tarefa única.

1. **Identifique o que é crítico.** O que, se caísse na mão errada, causaria dano? Endereço, documentos, acesso ao e-mail, ao

banco, ao WhatsApp, fotos íntimas, sua rotina, a identidade de uma fonte.

2. **Analise as ameaças.** Quem poderia querer isso, e por quê? Golpistas em massa, um ex-parceiro, um concorrente, alguém que você irritou na internet.
3. **Analise as vulnerabilidades.** Por onde a informação crítica pode escapar? Senha repetida, perfil aberto, foto com localização, SMS como segundo fator.
4. **Avalie o risco.** Combine a chance de acontecer com o tamanho do estrago. Um vazamento provável e grave vem primeiro.
5. **Aplique contramedidas.** Corrija as vulnerabilidades mais arriscadas primeiro. Depois, volte ao passo 1: sua vida muda, e o ciclo também.

> **A PERGUNTA QUE RESUME TUDO**
>
> Antes de postar, cadastrar ou responder qualquer coisa, pergunte: **"Se a pessoa errada juntasse isto com o que já existe sobre mim, o que ela conseguiria fazer?"**

Os três erros de pensamento

"Eu não sou ninguém, ninguém vai me atacar." A maioria dos ataques não é pessoal. Robôs testam milhões de senhas vazadas; golpistas disparam o mesmo golpe para milhares de números. Você não precisa ser importante, só precisa estar na lista.

"Não tenho nada a esconder." Você fecha a porta do banheiro e não deixa a senha do banco colada na geladeira. Privacidade não é esconder algo errado, é controlar quem sabe o quê sobre você.

“Já está tudo vazado mesmo.” Muita coisa provavelmente já vazou. Mas cada camada de proteção que você adiciona hoje torna o vazamento de ontem menos útil: uma senha vazada não serve se você já trocou e ativou dois fatores.

CHECKLIST DO CAPÍTULO

- [ ] Escrevi uma lista com as 5 coisas que mais me prejudicariam se vazassem.
- [ ] Pensei em quem poderia querer cada uma delas.

CAPÍTULO 2

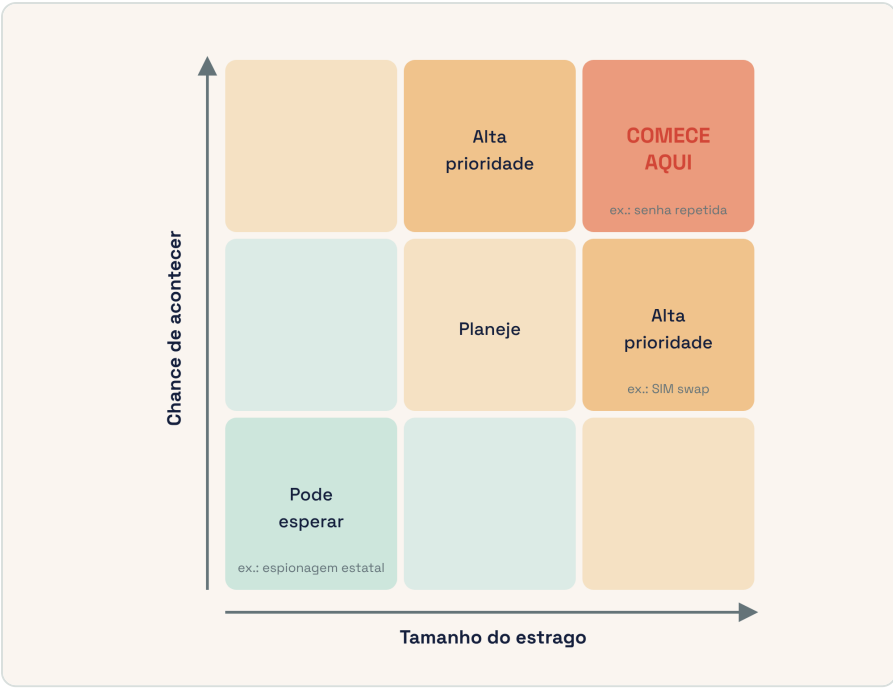
Seu modelo de ameaças

Não existe “segurança máxima” que sirva para todo mundo. Uma jornalista investigando uma milícia e um estudante que só quer não perder o Instagram precisam de coisas muito diferentes. Aplicar o nível da jornalista na vida do estudante gera cansaço e desistência; aplicar o nível do estudante na vida da jornalista pode custar caro.

Modelo de ameaças é o nome bonito para responder, com honestidade, a cinco perguntas.

As cinco perguntas

1. **O que eu quero proteger?** Contas, dinheiro, endereço, identidade, conversas, pessoas próximas.
2. **De quem?** Golpistas aleatórios, alguém que me conhece, uma empresa, um grupo organizado.
3. **Qual a chance de precisar?** Já aconteceu algo? Tenho exposição pública? Tenho inimigos?
4. **Qual o tamanho do estrago se falhar?** Constrangimento, prejuízo financeiro, risco físico.
5. **Quanto esforço estou disposto a fazer?** Tempo, dinheiro e conveniência que posso abrir mão.



Cruze a chance com o estrago: o canto superior direito é por onde começar.

Perfis comuns

Encontre o perfil mais parecido com o seu. Você pode ser mais de um.

Perfil	Ameaça principal	Até onde ir neste livro
Usuário comum	Golpes em massa, senha vazada, WhatsApp clonado	Partes 1 e 2 completas
Pequeno negócio / vendedor online	Golpes direcionados, invasão de contas da loja, falso cliente	Partes 1 a 3
Criador de conteúdo / pessoa pública	Exposição de endereço, perseguição, ataques em massa nas redes	Partes 1 a 3 e Capítulos 10 e 12
Vítima de perseguição ou violência doméstica	Alguém próximo, com acesso físico e conhecimento da sua vida	Tudo, com atenção ao Capítulo 7 e 12
Jornalista, ativista, pesquisador	Grupos organizados, vigilância, exposição de fontes	Tudo

QUANDO O ATACANTE É ALGUÉM PRÓXIMO

Se a ameaça é um parceiro ou ex-parceiro, mudanças bruscas (trocar todas as senhas de uma vez, sumir das redes) podem alertar a pessoa e aumentar o risco. Planeje com calma, de um aparelho que ela não conhece, e procure apoio: no Brasil, o **Ligue 180** atende mulheres em situação de violência, e a polícia civil registra ocorrências de perseguição (crime previsto no art. 147-A do Código Penal).

O atacante que você deve imaginar

Pense no atacante como alguém com três características: **recursos** (tempo, dinheiro, ferramentas), **motivação** (o quanto ele quer *você* em particular) e **acesso** (ele já te conhece? mora perto? tem a senha

do seu Wi-Fi?).

- Um **golpista em massa** tem bons recursos, motivação baixa por você e nenhum acesso. Ele desiste rápido. O básico já o derrota.
- Um **conhecido mal-intencionado** tem poucos recursos, motivação alta e muito acesso. Ele sabe suas respostas de segurança e já viu você digitar a senha. Contra ele, o que importa é o que é físico e pessoal.
- Um **grupo organizado** tem tudo: recursos, motivação e paciência para conseguir acesso. Contra ele, você precisa da Parte 4 inteira e de ajuda especializada.

CHECKLIST DO CAPÍTULO

- [ ] Respondi às cinco perguntas por escrito.
- [ ] Escolhi o perfil mais próximo e sei até que parte do livro vou.
- [ ] Marquei na matriz de risco as três ameaças que mais me preocupam.

PARTE 2

Básico

CAPÍTULO 3

Senhas que não te traem

Quase todo dia algum site tem seu banco de dados vazado. Quando isso acontece, as combinações de e-mail e senha vão parar em listas que circulam entre criminosos. Robôs pegam essas listas e testam cada par em centenas de outros serviços: bancos, redes sociais, lojas, e-mails. O nome disso é **credential stuffing** (recheio de credenciais), e funciona por um único motivo: as pessoas repetem senhas.

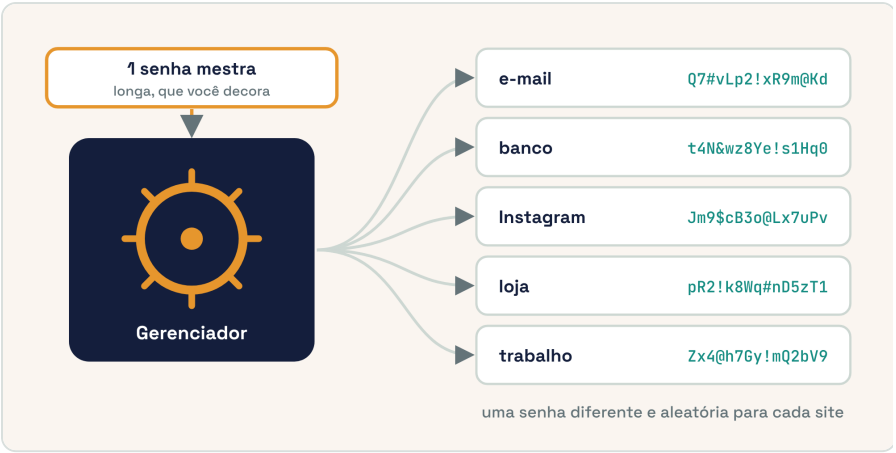
A regra de ouro

Uma senha diferente para cada conta. Se você só fizer uma coisa deste capítulo, faça essa. Uma senha vazada de um site de receitas não pode abrir o seu e-mail.

Ninguém consegue decorar cem senhas diferentes, e não precisa: é para isso que existe o **gerenciador de senhas**.

Gerenciador de senhas

Um gerenciador é um cofre criptografado. Você decora **uma** senha forte (a senha mestra) e ele guarda, gera e preenche todas as outras.



Uma senha mestra forte protege um cofre com senhas únicas e aleatórias.

Boas opções, todas com versão para celular e computador:

- **Bitwarden**: código aberto, plano gratuito completo.
- **1Password**: pago, muito bem acabado.
- **Proton Pass**: do mesmo grupo do Proton Mail, com plano gratuito.
- **O gerenciador do próprio sistema** (Senhas do iPhone/Mac, Gerenciador de Senhas do Google): melhor do que nada, mas prende você a um ecossistema.

> **COMECE PELO QUE IMPORTA**
>
> Você não precisa migrar tudo num dia. Instale o gerenciador e troque primeiro as senhas de: **e-mail principal, banco, WhatsApp/redes sociais e loja onde há cartão salvo**. O resto vai sendo trocado conforme você entra em cada site.

Como fazer uma senha mestra forte

O tamanho importa mais do que símbolos estranhos. Uma frase com palavras aleatórias é forte **e** fácil de lembrar:

```
jabuti-telhado-saxofone-rapadura-nove
```

Cinco ou seis palavras sem relação entre si, escolhidas ao acaso (não uma frase de música ou citação famosa). Evite:

- nomes, datas e times (estão nas suas redes sociais);
- trocar letras por números (`s3nh@`): os programas de quebra testam isso primeiro;
- a mesma base com finais diferentes (`Maria2023!`, `Maria2024!`).

> **A SENHA MESTRA NÃO VAI PARA O COFRE**
>
> Anote a senha mestra num papel e guarde em lugar seguro em casa até decorar. Se esquecê-la, nem a empresa do gerenciador consegue recuperar seus dados. Esse é justamente o ponto.

Descubra o que já vazou

O site **haveibeenpwned.com** mostra em quais vazamentos públicos o seu e-mail apareceu. Para cada um:

1. troque a senha daquele serviço;
2. troque em qualquer outro lugar onde usou a mesma senha;
3. ative dois fatores (próximo capítulo).

Muitos gerenciadores fazem esse monitoramento automaticamente e avisam quando uma senha salva aparece num vazamento.

Passkeys: o fim das senhas

Cada vez mais sites oferecem **passkeys** (chaves de acesso). Em vez de digitar uma senha, você confirma com a digital, o rosto ou o PIN do celular. Por trás, o aparelho usa criptografia e nunca envia um segredo que possa ser roubado. Uma passkey não pode ser vazada pelo site nem digitada numa página falsa. Quando um serviço importante oferecer, ative.

Perguntas de segurança

"Nome do primeiro animal de estimação" ou "cidade onde sua mãe nasceu" são respostas que estão no seu Facebook. Trate essas perguntas como senhas: responda com algo aleatório e guarde a resposta no gerenciador.

CHECKLIST DO CAPÍTULO

- [ ] Instalei um gerenciador de senhas no celular e no computador.
- [ ] Criei uma senha mestra com 5 ou mais palavras aleatórias.
- [ ] Troquei a senha do e-mail principal, do banco e das redes sociais.
- [ ] Conferi meu e-mail no haveibeenpwned.com.

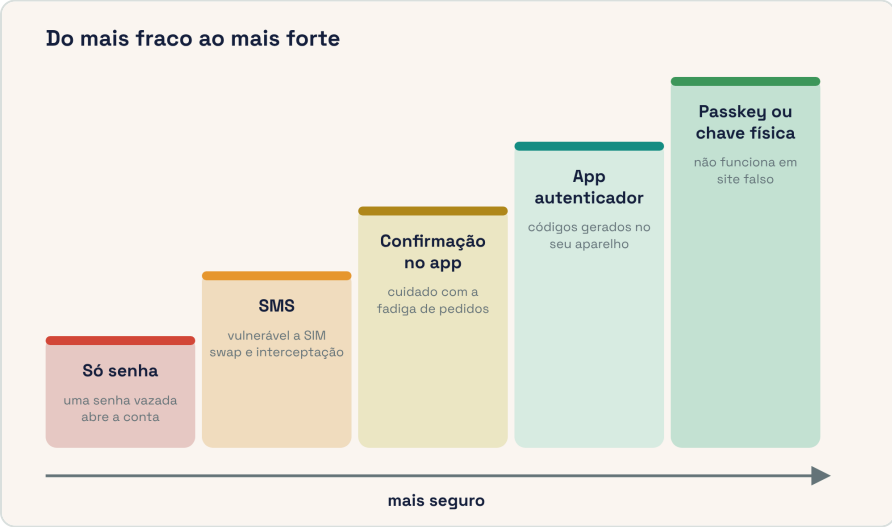
CAPÍTULO 4

Dois fatores: a segunda tranca

Mesmo a melhor senha pode vazar: num site invadido, numa página falsa, num vírus. A **autenticação em dois fatores** (2FA) exige uma segunda prova além da senha. Assim, quem tem só a senha fica do lado de fora.

As provas costumam ser de três tipos: **algo que você sabe** (senha, PIN), **algo que você tem** (celular, chave física) e **algo que você é** (digital, rosto). Dois fatores significa combinar dois tipos diferentes.

Nem todo segundo fator é igual



Do mais fraco ao mais forte. Qualquer degrau é melhor do que nenhum.

Código por SMS é o mais comum e o mais fraco. O código pode ser interceptado, e o número pode ser roubado por **SIM swap**: o golpista convence a operadora (às vezes com ajuda de um funcionário) a transferir sua linha para um chip dele. A partir daí, todos os seus códigos chegam no celular dele.

Aplicativo autenticador (Aegis, 2FAS, Google Authenticator, Microsoft Authenticator, ou o próprio gerenciador de senhas) gera códigos de 6 dígitos que mudam a cada 30 segundos, direto no aparelho, sem depender da operadora. É o padrão que você deve buscar.

Confirmação no app (“foi você que tentou entrar?”) é prática, mas cuidado com a **fadiga de notificação**: golpistas disparam dezenas de pedidos até a pessoa, cansada, apertar “sim”. Se chegar um

pedido que você não fez, **negue e troque a senha**: alguém já tem ela.

Chave de segurança física (como as YubiKey) e **passkeys** são as mais fortes: só funcionam no site verdadeiro, então nem uma página falsa perfeita consegue roubá-las.

Onde ativar primeiro

1. **E-mail principal.** Quem controla o seu e-mail recupera a senha de todo o resto.
2. **WhatsApp:** *Configurações → Conta → Confirmação em duas etapas*. Isso cria um PIN de 6 dígitos que impede a clonagem mais comum (veja o próximo capítulo).
3. **Banco e carteiras digitais.**
4. **Instagram, Facebook, TikTok, X**, e qualquer conta que, invadida, possa ser usada para enganar seus contatos.
5. **Apple ID / Conta Google**, que controlam o celular e os backups.

> **PROTEJA SUA LINHA CONTRA SIM SWAP**
>
> Ligue para a operadora e pergunte se é possível cadastrar uma **senha ou PIN para atendimento e troca de chip**. Depois, onde der, troque o SMS por aplicativo autenticador. Se o seu celular perder o sinal de repente e sem explicação, ligue de outro telefone para a operadora na hora: pode ser um SIM swap em andamento.

Códigos de recuperação

Ao ativar 2FA, quase todo serviço mostra **códigos de recuperação**: senhas de uso único para quando você perder o celular. Guarde-os no gerenciador de senhas e, para as contas mais importantes, também impressos em casa. Sem eles, perder o celular pode significar perder a conta para sempre.

CHECKLIST DO CAPÍTULO

- [ ] Ativei 2FA por aplicativo no meu e-mail principal.
- [ ] Ativei a confirmação em duas etapas do WhatsApp.
- [ ] Ativei 2FA no banco e nas redes sociais.
- [ ] Guardei os códigos de recuperação.
- [ ] Perguntei à operadora sobre senha para troca de chip.

CAPÍTULO 5

Golpes e engenharia social

A forma mais barata de invadir uma conta não é quebrar a criptografia: é convencer o dono a abrir a porta. **Engenharia social** é manipular pessoas para que entreguem informação, dinheiro ou acesso. **Phishing** é a versão por mensagem: e-mail, SMS, WhatsApp ou ligação fingindo ser alguém confiável.

Todo golpe, por mais criativo, usa as mesmas alavancas emocionais: **urgência** (“sua conta será bloqueada hoje”), **medo** (“detectamos uma compra de R$ 4.890”), **autoridade** (“aqui é do setor de segurança do banco”), **ganância** (“você foi sorteado”) e **afeto** (“mãe, troquei de número”).

Anatomia de uma mensagem falsa



Os sinais estão quase sempre lá. O golpe aposta que você vai ter pressa.

Os golpes mais comuns no Brasil

Clonagem de WhatsApp. Alguém pede "o código de 6 dígitos que chegou por SMS", fingindo ser de uma loja, de uma pesquisa ou de um sorteio. Esse código é a ativação do seu WhatsApp em outro celular. **Nunca repasse esse código para ninguém.** A confirmação em duas etapas (Capítulo 4) bloqueia a maioria dessas tentativas.

"Mãe, troquei de número." O golpista usa sua foto e seu nome em outro número e pede um Pix urgente aos seus parentes. Combine com a família: **pedido de dinheiro por mensagem só vale depois**

de uma ligação de voz para o número antigo, ou com uma pergunta que só vocês saibam responder.

Falsa central do banco. Você recebe uma ligação ou SMS sobre uma "compra suspeita". O atendente é educado, sabe seu nome e parte do CPF (dados de vazamentos), e pede para você confirmar dados, instalar um aplicativo "de segurança" ou fazer um Pix "de teste". O banco **nunca** pede senha, código, Pix de teste nem instalação de aplicativo por telefone. Desligue e ligue você mesmo para o número do verso do cartão.

Falso suporte técnico ou acesso remoto. Pedem para instalar AnyDesk, TeamViewer ou um app parecido "para resolver um problema". Com isso, a pessoa controla seu celular ou computador enquanto você está no banco.

Boleto e comprovante falsos. Boleto com código de barras adulterado (o dinheiro vai para outra conta) ou comprovante de Pix editado, enviado por um "comprador" de marketplace. Confira sempre o **beneficiário** antes de pagar e o **extrato** antes de entregar um produto.

Links de entrega, multa e "taxa". SMS dizendo que sua encomenda está retida ou que há uma multa a pagar, com link para uma página idêntica à dos Correios ou do Detran.

O método das três paradas

Quando uma mensagem pedir **ação** (clicar, pagar, informar, instalar):

1. **Pare.** A urgência é a arma do golpe. Nada sério precisa ser resolvido nos próximos dois minutos.

2. **Confira por outro caminho.** Não responda à mensagem nem ligue para o número que veio nela. Abra o aplicativo oficial, digite o endereço do site você mesmo ou ligue para o número oficial.
3. **Pergunte a alguém.** Mostrar para outra pessoa quebra o transe da urgência. Golpes que parecem perfeitos para quem está nervoso parecem óbvios para quem está de fora.

> **ENDEREÇOS QUE ENGANAM**
>
> Golpistas registram endereços parecidos: `itau-seguranca.com`, `bradesco.atendimento-online.net`, `santander.com.br.login-cliente.xyz`. O que vale é o **final** do domínio, logo antes da primeira barra. Em `santander.com.br.login-cliente.xyz`, o dono é `login-cliente.xyz`, não o Santander.

Se você caiu

Acontece com gente inteligente e atenta. O que importa é a velocidade:

- **Pix ou transferência:** ligue para o banco imediatamente e peça o **MED** (Mecanismo Especial de Devolução do Pix). Quanto antes, maior a chance de bloquear o valor na conta do golpista.
- **Senha ou código entregues:** troque a senha na hora, encerre as outras sessões (quase todo app tem "sair de todos os dispositivos") e confira se o 2FA ainda é seu.
- **App de acesso remoto instalado:** desligue a internet do aparelho, desinstale o app e procure o banco.

- **Registre um boletim de ocorrência**, que muitos estados permitem fazer pela internet.

CHECKLIST DO CAPÍTULO

- [ ] Combinei com minha família uma regra para pedidos de dinheiro por mensagem.
- [ ] Salvei os números oficiais do meu banco nos contatos.
- [ ] Sei o que é o MED do Pix e como pedir.

CAPÍTULO 6

Celular e computador em ordem

De nada adianta uma senha perfeita se o aparelho onde você a digita está desatualizado, desbloqueado em cima da mesa ou cheio de aplicativos que leem tudo. Este capítulo é a faxina básica, e quase tudo nele se faz uma vez só.

Atualize. Sempre.

A maioria das invasões de aparelhos explora falhas que **já foram corrigidas**: o problema é que a vítima não instalou a correção. Ative as atualizações automáticas do sistema e dos aplicativos. Um celular que não recebe mais atualizações do fabricante (em geral, após 3 a 7 anos, dependendo da marca) deve deixar de ser usado para banco e trabalho.

Bloqueio de tela de verdade

- Use **PIN de 6 dígitos ou mais**, ou senha alfanumérica. Padrões de desenho são fáceis de adivinhar pelas marcas de dedo na tela e por quem olha por cima do ombro.
- Biometria (digital, rosto) é prática no dia a dia. O PIN continua sendo a chave mestra, então ele precisa ser bom.
- Bloqueio automático em 30 segundos a 1 minuto.

- **Esconda o conteúdo das notificações na tela bloqueada.** Senão, qualquer pessoa com o celular na mão lê seus códigos de verificação sem desbloquear nada.

Criptografia do disco

Se o aparelho for roubado, a criptografia impede que leiam os arquivos ligando o disco em outro lugar.

- **iPhone e Android modernos:** já vêm criptografados quando há bloqueio de tela.
- **Windows:** ative o **BitLocker** (versões Pro) ou a **Criptografia do Dispositivo** (muitos notebooks com Windows Home). Guarde a chave de recuperação fora do computador.
- **Mac:** ative o **FileVault**.
- **Linux:** escolha criptografar o disco (LUKS) na instalação.

Aplicativos e permissões

Cada app instalado é uma porta a mais. Uma vez por mês, faça a revisão:

1. Desinstale o que você não usou nos últimos três meses.
2. Revise as permissões: lanterna não precisa de contatos; jogo não precisa de microfone; quase nada precisa de **localização o tempo todo** (use “só durante o uso”).
3. Instale apenas das lojas oficiais. **APK de fora da loja**, enviado por link ou mensagem, é o caminho mais comum para vírus que roubam bancos no Android.

4. Desconfie de apps que pedem **acessibilidade** sem motivo: essa permissão deixa o app ler e tocar na sua tela. É exatamente o que os vírus bancários pedem.

Backup: a defesa contra o pior dia

Celular roubado, disco queimado, vírus que sequestra arquivos (*ransomware*): com backup, tudo vira um incômodo; sem backup, vira perda. Siga a regra **3-2-1**:



Três cópias, dois tipos de lugar, uma fora de casa.

- **3** cópias dos seus dados (a original e mais duas);
- em **2** tipos de armazenamento diferentes (por exemplo, nuvem e HD externo);
- **1** cópia fora de casa (a nuvem conta).

Ative o backup automático do celular (iCloud ou Google) e, de vez em quando, copie fotos e documentos importantes para um HD externo que fica desconectado. Um backup que fica sempre

plugado pode ser criptografado junto com o resto por um ransomware.

Rastreio e apagamento remoto

Ative **Buscar iPhone** (Apple) ou **Encontre Meu Dispositivo** (Google) e teste uma vez para saber como funciona. No Brasil, cadastre também o celular no **Celular Seguro** (programa do governo federal), que permite pedir o bloqueio de bancos e da linha em poucos cliques caso o aparelho seja roubado. Anote o **IMEI** (digite `*#06#` no telefone) e guarde junto com a nota fiscal.

CHECKLIST DO CAPÍTULO

- [ ] Atualizações automáticas ligadas no celular e no computador.
- [ ] PIN de 6+ dígitos e notificações escondidas na tela bloqueada.
- [ ] Criptografia ativa no computador, com a chave de recuperação guardada.
- [ ] Revisei apps e permissões.
- [ ] Backup automático ligado e uma cópia num HD externo.
- [ ] Rastreio ativado, IMEI anotado, celular cadastrado no Celular Seguro.

PARTE 3

Intermediário

CAPÍTULO 7

Sua pegada digital

OSINT (*Open Source Intelligence*, inteligência de fontes abertas) é a arte de descobrir coisas sobre alguém usando só o que é público. Investigadores e jornalistas usam para o bem. Golpistas e perseguidores usam exatamente as mesmas técnicas. A melhor defesa é fazer você mesmo, antes deles, uma investigação sobre si.

Faça uma investigação sobre você

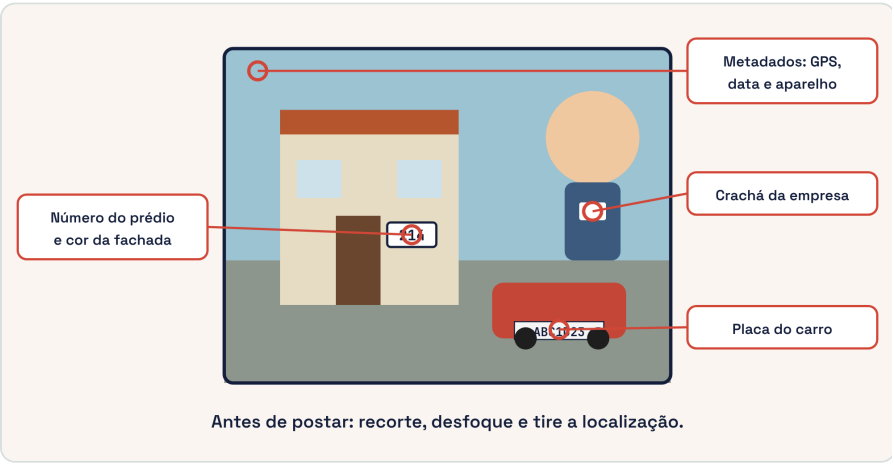
Reserve uma hora, abra uma janela anônima do navegador (para não ver resultados personalizados) e procure:

1. Seu **nome completo entre aspas**, sozinho e junto com sua cidade, profissão e escola.
2. Seus **apelidos e nomes de usuário**. Um mesmo @ usado em vários sites liga identidades que você achava separadas.
3. Seu **e-mail e telefone**. Eles aparecem em cadastros públicos, anúncios antigos e listas de contato de empresas.
4. Suas **fotos**, com busca reversa de imagem (Google Lens, Bing Visual Search ou TinEye). Ela mostra onde mais sua foto de perfil aparece.
5. Seu **CPF**, apenas para ver se aparece em diários oficiais ou documentos publicados. Nunca digite o CPF em sites "de consulta" desconhecidos.

Anote tudo o que achou numa tabela com três colunas: *onde está*, *o que revela* e *dá pra remover?*.

O que as fotos contam

Uma foto pode revelar muito mais do que você postou de propósito.



Uma foto comum e tudo o que ela pode entregar.

- **Metadados (EXIF).** Câmeras e celulares gravam dentro do arquivo a data, o modelo do aparelho e, muitas vezes, as **coordenadas GPS** de onde a foto foi tirada. Redes sociais grandes costumam apagar esses dados ao publicar, mas arquivos enviados como *documento*, por e-mail ou em sites menores podem manter tudo. Desative a localização no app de câmera, ou use a opção de remover a localização ao compartilhar (iPhone e Android modernos têm).

- **Fundo da imagem.** Fachada de casa, número do prédio, placa do carro, vista da janela, uniforme da escola dos filhos, crachá, tela do computador, reflexos em óculos e vidros.
- **Padrões.** Vários posts no mesmo lugar e no mesmo horário revelam rotina. Poste depois de sair do lugar, não durante.

> **O TESTE DO DESCONHECIDO**
>
> Antes de postar, imagine que um desconhecido mal-intencionado vai olhar a foto com lupa por dez minutos. O que ele descobriria? Recorte ou desfoque o que não precisa aparecer.

Redes sociais: diminua a vitrine

- Deixe perfis pessoais **privados** e revise quem são os seguidores.
- Esconda a **lista de amigos/seguidores**: ela revela família, cidade e escola.
- Tire do perfil: **data de nascimento completa, telefone, e-mail, empresa, cidade** (ou deixe visíveis só para amigos).
- Apague ou arquive posts antigos que revelam endereço, documentos, rotina ou a escola dos filhos.
- Desative a marcação automática em fotos e a sugestão do seu perfil por número de telefone ou e-mail.

Seus direitos pela LGPD

A **Lei Geral de Proteção de Dados** (Lei 13.709/2018) dá a você, entre outros, o direito de saber quais dados uma empresa tem sobre você, corrigi-los e pedir a **eliminação** dos dados tratados com base

no seu consentimento. Empresas são obrigadas a ter um canal para isso (procure por “Encarregado de dados”, “DPO” ou “Privacidade” no site). Se a empresa ignorar, você pode reclamar à **ANPD** (Autoridade Nacional de Proteção de Dados).

Nos buscadores, o Google tem um formulário para pedir a remoção de resultados com **dados pessoais sensíveis** (documentos, dados bancários, endereço e telefone em certos contextos, imagens íntimas). Removido do buscador, o conteúdo fica muito mais difícil de achar, mesmo que continue no site de origem.

CHECKLIST DO CAPÍTULO

- [ ] Fiz a investigação sobre mim e anotei o que achei.
- [ ] Desativei a localização na câmera.
- [ ] Deixei meus perfis pessoais privados e tirei dados sensíveis da bio.
- [ ] Pedi a remoção do que encontrei e dava para remover.

CAPÍTULO 8

Navegar sem deixar rastro fácil

Cada site que você abre conversa com dezenas de outras empresas: anunciantes, redes de rastreamento, ferramentas de análise. Elas montam um perfil do que você lê, compra e pesquisa, e esse perfil é vendido, cruzado e, às vezes, vazado. Neste capítulo, você vai entender quem vê o quê e cortar a maior parte desse rastreio.

Quem vê o quê

Quando você acessa um site, várias partes podem ver informações diferentes:

- **A rede local** (o Wi-Fi do café, do trabalho, de casa) vê que você está conectado e quais sites você visita.
- **O provedor de internet** vê os mesmos destinos, para todos os seus aparelhos.
- **O site** vê seu IP, seu navegador e tudo o que você faz nele, e pode ligar isso à sua conta se você estiver logado.
- **Rastreadores de terceiros** veem você passando por milhares de sites diferentes e juntam tudo num único perfil.

O **HTTPS** (o cadeado na barra de endereço) criptografa o *conteúdo* da conversa entre você e o site: senhas, mensagens, o que você digita. Hoje quase todo site usa. Mas ele não esconde *qual* site você

está visitando.

Navegador e extensões

O navegador é a ferramenta que você mais usa. Vale escolher bem:

- **Firefox**, com a extensão **uBlock Origin**: ótimo equilíbrio entre privacidade e compatibilidade.
- **Brave**: já vem com bloqueio de anúncios e rastreadores ligado.
- **Mullvad Browser**: feito pela equipe do Tor, para resistir a rastreamento sem usar a rede Tor.
- **Chrome e Edge**: funcionam, mas as empresas por trás deles vivem de dados. Se usar, ao menos instale um bloqueador de conteúdo.

> **MENOS EXTENSÕES, MAIS SEGURANÇA**
>
> Cada extensão pode ler as páginas que você visita. Extensões "de cupom", "de download de vídeo" e "de VPN grátis" estão entre as que mais roubam dados. Mantenha o mínimo: um bloqueador de conteúdo e o gerenciador de senhas.

Impressão digital do navegador

Mesmo sem cookies, um site pode reconhecer você pela combinação de detalhes do seu aparelho: tamanho da tela, fontes instaladas, placa de vídeo, fuso horário, idioma. Essa combinação é tão única que funciona como uma **impressão digital** (*fingerprint*).

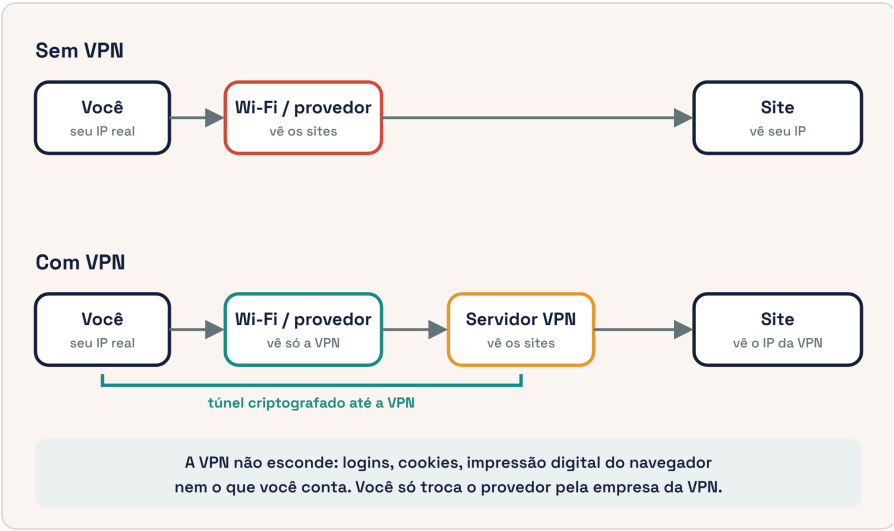
O site **coveryourtracks.eff.org**, da organização EFF, mostra o quão única é a sua. Navegadores como o Tor Browser e o Mullvad Browser se defendem fazendo todos os usuários parecerem iguais.

DNS: a lista telefônica

Antes de abrir um site, o aparelho pergunta a um servidor de **DNS** qual é o endereço numérico daquele nome. Por padrão, quem responde é o seu provedor, que fica sabendo de cada site que você procura. Ative o **DNS seguro** (DNS sobre HTTPS) no navegador ou o **DNS privado** no Android, usando um serviço como **Quad9** (que também bloqueia domínios maliciosos conhecidos) ou **Cloudflare 1.1.1.1**.

VPN: o que faz e o que não faz

A VPN é a ferramenta de privacidade mais vendida e a mais mal-entendida.



A VPN muda quem pode ver seu tráfego. Ela não apaga quem você é.

Uma VPN faz:

- esconder da rede local e do provedor quais sites você visita;
- esconder dos sites o seu IP real (eles veem o IP da VPN);
- proteger você em Wi-Fi público desconhecido.

Uma VPN não faz:

- deixar você anônimo: se você entra na sua conta do Google, o Google sabe que é você;
- impedir cookies, rastreadores ou impressão digital do navegador;
- proteger contra golpes, vírus ou senhas fracas.

E o mais importante: **a VPN passa a ver tudo o que o provedor via**. Você troca de quem confia. VPN gratuita desconhecida geralmente se paga vendendo justamente os seus dados. Se precisar de uma,

prefira serviços com auditorias independentes públicas, como **Mullvad** ou **Proton VPN** (que tem um plano gratuito honesto).

CHECKLIST DO CAPÍTULO

- [ ] Instalei um bloqueador de conteúdo (ou troquei de navegador).
- [ ] Removi extensões que não uso.
- [ ] Ativei DNS seguro no navegador e no celular.
- [ ] Sei para que serve (e para que não serve) uma VPN.

CAPÍTULO 9

Mensagens e e-mail

O que você escreve num aplicativo de mensagens passa por servidores de alguma empresa. A pergunta é: **essa empresa consegue ler?** E, mesmo que não consiga ler o conteúdo, **o que ela sabe sobre com quem, quando e de onde você conversa?**

Criptografia de ponta a ponta

Na **criptografia de ponta a ponta** (*E2EE*), a mensagem é trancada no seu celular e só é destrancada no celular de quem recebe. O servidor carrega um pacote lacrado que não consegue abrir. Nem a empresa, nem um invasor do servidor, nem quem pedir os dados à empresa lê o conteúdo.



Ponta a ponta: o servidor só carrega o envelope lacrado.

Conteúdo não é tudo: os metadados

Metadados são os dados *sobre* a conversa: quem falou com quem, quando, por quanto tempo, de onde, em que grupos. Mesmo sem ler nada, eles contam muito. Saber que alguém ligou para um oncologista, depois para a seguradora e depois para um advogado conta uma história inteira.

Comparando os aplicativos

	Signal	WhatsApp	Telegram
Ponta a ponta por padrão	Sim, em tudo	Sim, nas conversas	**Não**: só em "chats secretos"
Grupos com ponta a ponta	Sim	Sim	**Não**
Metadados guardados	Mínimos	Muitos (contatos, horários, uso)	Muitos
Backup na nuvem	Opcional, sempre criptografado	Pode ser criptografado (você precisa ativar)	Conversas comuns ficam no servidor
Exige número de telefone	Sim, mas pode esconder com nome de usuário	Sim	Sim, mas pode esconder com nome de usuário

Para conversas sensíveis, use Signal. Para o dia a dia, o WhatsApp protege bem o conteúdo, desde que você cuide do backup. O Telegram é ótimo para canais e grupos públicos, mas não deve ser tratado como mensageiro seguro.

> **O PONTO FRACO DO WHATSAPP É O BACKUP**
>
> As conversas são de ponta a ponta, mas o backup no Google Drive ou no iCloud **não é**, a menos que você ative em *Configurações → Conversas → Backup de conversas → Backup protegido por criptografia de ponta a ponta*.

Boas práticas de mensagens

- **Mensagens temporárias** para conversas sensíveis: elas somem depois de um tempo e não ficam esperando um celular roubado.
- **Verifique o número de segurança** (Signal) ou o código de segurança (WhatsApp) com contatos importantes, pessoalmente. Isso garante que ninguém está no meio da conversa.
- Lembre-se de que **a outra ponta também é uma ponta**: um print ou um celular desbloqueado do outro lado revela tudo. A criptografia não protege contra quem recebeu a mensagem.

E-mail

O e-mail comum não é criptografado de ponta a ponta. Seu provedor consegue ler, e muitas vezes lê, para anúncios ou filtros.

- Para mais privacidade, provedores como **Proton Mail** e **Tuta** guardam suas mensagens criptografadas e não vivem de anúncios. Entre usuários do mesmo serviço, a mensagem é de ponta a ponta.
- Seu e-mail principal é a chave de recuperação de tudo. Ele merece a senha mais forte e o melhor segundo fator que você tiver.

Aliases: um e-mail para cada cadastro

Um **alias** é um endereço descartável que encaminha para o seu e-mail real. Serviços como **SimpleLogin**, **addy.io**, **Firefox Relay** e o **Ocultar Meu E-mail** da Apple criam um endereço diferente para cada site. Vantagens:

- quando um site vaza, só aquele alias vaza, e você o desliga;
- quando chega spam num alias, você sabe exatamente quem vendeu seu e-mail;
- seu endereço real fica fora das listas que circulam entre golpistas.

CHECKLIST DO CAPÍTULO

- [ ] Instalei o Signal e convidei as pessoas com quem tenho conversas sensíveis.
- [ ] Ativei o backup criptografado do WhatsApp.
- [ ] Uso mensagens temporárias quando faz sentido.
- [ ] Criei aliases para cadastros novos.

PARTE 4

Avançado

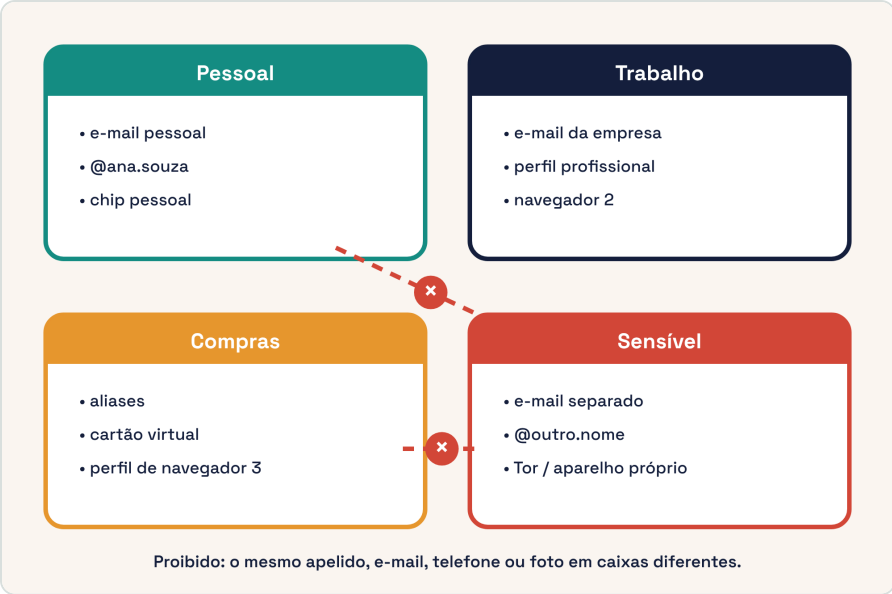
CAPÍTULO 10

Compartimentalização

Navios grandes são divididos em compartimentos estanques: se o casco fura num ponto, a água enche só aquele compartimento e o navio continua flutuando. Na vida digital, a ideia é a mesma. **Compartimentalizar** é separar suas atividades em "caixas" que não se tocam, de modo que o vazamento de uma não afunde as outras.

As identidades que você já tem

Pense nas diferentes partes da sua vida: **pessoal** (família, amigos), **profissional**, **financeira**, **pública** (se você publica conteúdo ou opina na internet) e, para alguns, uma **sensível** (um projeto, uma pesquisa, um grupo de apoio, algo que não deve ser ligado ao seu nome).



Cada caixa com seus próprios dados. As linhas vermelhas são as que não podem existir.

Cada caixa deve ter, idealmente, seus próprios:

- **e-mail** (ou pelo menos alias diferente);
- **nome de usuário**, sem repetição entre caixas;
- **número de telefone**, quando a separação importa de verdade;
- **perfil de navegador** (ou navegador diferente);
- **foto de perfil** (fotos são ligadas facilmente por busca reversa).

Os pontos de cruzamento

Compartimentos vazam pelos pontos onde se tocam. Os mais comuns:

- **E-mail ou telefone de recuperação:** a conta “anônima” que tem o seu celular pessoal como recuperação não é anônima.
- **Nome de usuário repetido:** é a primeira coisa que qualquer investigador procura.
- **Mesmo navegador logado:** cookies e contas ligam as atividades.
- **Pagamentos:** cartão, Pix e chave Pix carregam seu nome e CPF.
- **Estilo:** expressões, erros de digitação, assuntos favoritos e horários de atividade parecidos entre perfis.
- **Contatos:** seguir as mesmas pessoas ou ser seguido por seus amigos.
- **Arquivos:** documentos e fotos carregam metadados (nome do autor, aparelho, local).

> **COMECE SIMPLES**
>
> Para a maioria das pessoas, compartimentalizar é só: **um e-mail para a vida pessoal, um para o trabalho, um para cadastros e compras, e aliases para tudo o que é descartável**. Isso já corta a maior parte do cruzamento de dados.

Separação no navegador e no sistema

Do mais simples ao mais forte:

1. **Perfis do navegador** (Firefox, Chrome e Edge têm): cada perfil tem cookies, histórico e logins separados.
2. **Contêineres do Firefox** (extensão *Multi-Account Containers*): abas de cores diferentes que não compartilham cookies.
3. **Navegadores diferentes** para cada identidade.

4. **Usuários diferentes no sistema** ou um **segundo aparelho** dedicado.
5. **Máquinas virtuais** (como VirtualBox) ou sistemas feitos para isolamento, como o **Qubes OS**, para quem precisa do nível mais alto.

Celular separado

Para uma identidade realmente sensível, o mais seguro é um aparelho separado, que nunca recebe seu chip pessoal, sua conta Google ou Apple pessoal, nem é ligado no Wi-Fi de casa ao mesmo tempo que o celular pessoal (os dois aparecem juntos na mesma rede). Isso tem custo e dá trabalho, por isso só vale se o seu modelo de ameaças (Capítulo 2) pedir.

CHECKLIST DO CAPÍTULO

- ☐ Listei minhas "caixas" de identidade.
- ☐ Separei pelo menos o e-mail pessoal do e-mail de cadastros.
- ☐ Conferi o e-mail e o telefone de recuperação das contas que deveriam ser separadas.
- ☐ Criei perfis de navegador para as atividades que não devem se misturar.

CAPÍTULO 11

Anonimato: Tor e Tails

Privacidade é controlar quem vê o que você faz. **Anonimato** é fazer algo sem que liguem a ação a você. São coisas diferentes, e o anonimato é muito mais difícil: basta um descuido para desfazer todo o resto.

Quem precisa de anonimato de verdade? Jornalistas protegendo fontes, pessoas denunciando abusos, quem vive sob censura, quem pesquisa assuntos sensíveis (uma doença, uma orientação sexual, uma situação de violência) e não quer isso ligado ao próprio nome.

Como o Tor funciona

O **Tor** é uma rede mantida por voluntários. O **Tor Browser** envia sua conexão por três servidores escolhidos ao acaso, cada um com uma camada de criptografia, como as camadas de uma cebola (o símbolo do projeto).



Nenhum servidor sozinho sabe ao mesmo tempo quem você é e o que você acessa.

- O **primeiro** servidor (guarda) sabe o seu IP, mas não sabe que site você acessa.
- O **do meio** não sabe nem uma coisa nem outra.
- O **último** (saída) sabe o site, mas não sabe quem você é.

Sites com endereço **.onion** ficam dentro da rede Tor, e nesse caso nem existe servidor de saída: a conexão é protegida do começo ao fim.

Usando o Tor Browser direito

- Baixe só do site oficial, **torproject.org**.
- **Não faça login em contas pessoais** no Tor. Entrar no seu Instagram pelo Tor só mostra ao Instagram que você usa Tor.
- **Não instale extensões** nem mexa nas configurações avançadas: o Tor Browser protege você fazendo todos os usuários parecerem iguais, e cada mudança torna o seu diferente.
- Use o nível de segurança **"Mais seguro"** ou **"O mais seguro"** quando o risco for alto. Alguns sites quebram, e esse é o preço.

- **Não abra documentos baixados** (PDF, Word) com o computador conectado: eles podem carregar coisas da internet fora do Tor e revelar seu IP.
- Prefira sites com HTTPS: o servidor de saída pode ver o conteúdo do que não for criptografado.

Tails: o sistema que esquece

O **Tails** é um sistema operacional que roda a partir de um **pendrive**, sem tocar no disco do computador. Toda a internet passa pelo Tor e, ao desligar, **tudo é apagado**: histórico, arquivos, rastros. É usado por jornalistas e pessoas em situações de alto risco. Opcionalmente, guarda alguns arquivos num espaço criptografado do próprio pendrive.

Os erros que quebram o anonimato

A tecnologia raramente falha. As pessoas falham. Os erros clássicos:

1. **Misturar identidades:** entrar no e-mail pessoal "rapidinho" na mesma sessão.
2. **Reutilizar nomes de usuário** ou e-mails que já apareceram ligados ao seu nome.
3. **Contar detalhes da própria vida:** cidade, profissão, idade, o clima de hoje, o jogo que você assistiu.
4. **Estilo de escrita:** gírias regionais, erros de digitação característicos, a forma de pontuar.
5. **Horários:** atividade sempre nos mesmos horários revela fuso horário e rotina.

6. **Arquivos com metadados:** fotos com GPS, documentos com o nome do autor nas propriedades.
7. **Pagamentos:** qualquer pagamento com cartão ou Pix leva ao seu CPF.
8. **Confiar em quem está do outro lado:** anonimato técnico não protege contra alguém que você mesmo convenceu a confiar.

SOBRE A LEGALIDADE

No Brasil, usar Tor, Tails e VPN é legal. A Constituição protege a privacidade e o sigilo das comunicações, mas também **veda o anonimato** na manifestação do pensamento: a responsabilidade pelo que se diz continua existindo. Anonimato é uma ferramenta de proteção, não uma licença.

CHECKLIST DO CAPÍTULO

- [ ] Entendi a diferença entre privacidade e anonimato.
- [ ] Sei instalar e usar o Tor Browser sem misturar contas pessoais.
- [ ] Conheço os oito erros que quebram o anonimato.

CAPÍTULO 12

Segurança física e em trânsito

A melhor criptografia do mundo não ajuda se alguém olha a senha por cima do seu ombro, pega o celular desbloqueado da mesa ou instala algo no seu notebook enquanto você vai ao banheiro. O mundo digital começa no mundo físico.

Olhos por cima do ombro

- Digite PINs e senhas cobrindo a tela, em lugares públicos e também perto de conhecidos.
- Um **filtro de privacidade** (película que escurece a tela vista de lado) custa pouco e protege no ônibus, no avião e no café.
- Cuidado com **câmeras**: de segurança, de outros celulares, até reflexos em janelas.
- Nunca deixe o aparelho desbloqueado sem supervisão, nem por "dois minutinhos".

Wi-Fi público e carregadores

O Wi-Fi do aeroporto, do shopping ou do hotel ficou menos perigoso desde que quase todo site passou a usar HTTPS. Os riscos que sobram:

- **Redes falsas** com o nome do lugar ("Aeroporto_Free"), criadas por quem quer ver o seu tráfego ou mostrar páginas de login

falsas.

- **Páginas de cadastro** que pedem dados demais para liberar o acesso.

Prefira usar o **4G/5G do celular** ou rotear dele. Se precisar do Wi-Fi público, uma VPN confiável ajuda.

Em tomadas USB públicas, o cabo pode transmitir dados, e não só energia. Use o **seu carregador na tomada comum**, ou um adaptador "só carga", e negue o pedido de "confiar neste computador" quando aparecer.

Desligado é mais seguro que bloqueado

Um celular **ligado e já desbloqueado alguma vez desde que foi ligado** guarda chaves de criptografia na memória, o que facilita ferramentas de extração forense. Um celular **desligado** (ou reiniciado e ainda não desbloqueado) está no estado mais protegido possível.

Por isso, em situações de risco (uma abordagem, um protesto, uma travessia de fronteira), **desligue o aparelho**. Outros atalhos úteis:

- **iPhone:** segure o botão lateral e um botão de volume até aparecer a tela de desligar, e toque em *Cancelar*. O Face ID e o Touch ID ficam desativados até o código ser digitado. (Cuidado: apertar o botão lateral várias vezes seguidas pode acionar a ligação de emergência.)
- **Android:** o modo **Bloqueio** (*Lockdown*), no menu do botão liga/desliga, desativa a biometria até o PIN ser digitado. Em alguns aparelhos, ele precisa ser ativado nas configurações de tela de bloqueio.

Viagens

- Antes de viajar, faça **backup** e leve só o necessário no aparelho.
- Para viagens de alto risco, considere um **aparelho de viagem** com o mínimo de contas.
- Nas redes sociais, **poste depois de voltar**: anunciar que a casa está vazia por dez dias é um convite.
- Cuidado com **etiquetas de bagagem** e **cartões de embarque** em fotos: o código de barras do cartão contém seu nome e o localizador da reserva, que dá acesso a ela.

Em casa

- Troque a **senha padrão do roteador** (a do painel de administração, não só a do Wi-Fi) e mantenha o roteador atualizado.
- Crie uma **rede de convidados** para visitas e para aparelhos "inteligentes" (TV, lâmpadas, câmeras), separando-os dos computadores e celulares.
- Câmeras de segurança conectadas precisam de senha forte e dois fatores: câmeras invadidas são uma forma comum de espionagem doméstica.
- Fragmente ou rasgue **documentos e correspondências** com dados pessoais antes de jogar fora.

RASTREADORES ESCONDIDOS

Pequenos localizadores Bluetooth (como AirTag e similares) já foram usados para perseguir pessoas. iPhones avisam automaticamente quando um rastreador desconhecido acompanha você; no Android, a busca por rastreadores desconhecidos fica nas configurações de segurança. Se encontrar um, não destrua: ele é prova. Procure a polícia.

CHECKLIST DO CAPÍTULO

- [ ] Sei desativar a biometria rapidamente no meu celular.
- [ ] Uso meu próprio carregador em lugares públicos.
- [ ] Troquei a senha do painel do roteador e criei uma rede de convidados.
- [ ] Posto viagens só depois de voltar.

PARTE 5

Na prática

CAPÍTULO 13

Quando a OPSEC falhou

Os casos abaixo são públicos e bem documentados. Em todos eles, as pessoas envolvidas tinham motivos fortes para se proteger e muitas vezes usavam boas ferramentas. Mesmo assim, um detalhe humano entregou tudo. Eles estão aqui pelas lições, que valem para qualquer pessoa.

O apelido que ligou tudo

Em 2011, alguém usando o apelido **"altoid"** divulgou em fóruns da internet um novo site anônimo de comércio na rede Tor. Meses depois, o mesmo apelido "altoid" postou num fórum de programação pedindo ajuda e, para contato, deixou um e-mail com o próprio nome. Anos depois, investigadores ligaram as duas postagens. Isso ajudou a identificar o criador do site, preso em 2013 numa biblioteca de São Francisco, nos Estados Unidos.

Lição: um único ponto de contato entre identidades basta. Um apelido, um e-mail de recuperação, uma foto. Compartimentos (Capítulo 10) não podem ter exceções "só dessa vez".

O mapa de corridas que mostrou bases militares

Em janeiro de 2018, um estudante australiano percebeu que o **mapa de calor público** do aplicativo de corridas Strava, que mostrava os trajetos de milhões de usuários, desenhava com clareza o contorno e as rotinas de bases militares em países como Síria e Afeganistão. Soldados usavam relógios esportivos para correr dentro das bases, e o aplicativo publicava os trajetos agregados.

Lição: dados "anônimos" e "agregados" ainda revelam padrões. Configure os aplicativos de exercício para não mostrar o começo e o fim dos trajetos (em geral, sua casa) e para manter as atividades privadas.

A foto que trazia as coordenadas

Em dezembro de 2012, um empresário que a polícia de Belize procurava para interrogar estava escondido, e jornalistas que o acompanhavam publicaram uma foto dele na internet. O arquivo da imagem ainda continha os **metadados de GPS** do celular que a tirou, apontando um local na Guatemala. Em poucas horas, a localização estava circulando.

Lição: antes de publicar ou enviar uma imagem, confira se a localização foi removida. Não confie que "o site apaga": nem todos apagam, e nem todo envio passa por um site.

Os pontinhos amarelos

Em 2017, um documento sigiloso foi vazado para jornalistas, que publicaram uma imagem da cópia impressa. Muitas impressoras coloridas imprimem, em pontinhos amarelos quase invisíveis, um código com o **número de série da impressora e a data e hora da impressão**. Esse detalhe, junto com os registros de quem havia impresso o documento, levou rapidamente à identificação da fonte.

Lição: documentos carregam rastros que você não vê: metadados em arquivos digitais, marcas em papéis impressos, registros de acesso em sistemas. Quem protege uma fonte precisa conhecer esses rastros tanto quanto ela.

O padrão por trás dos casos

Nenhum desses casos foi resolvido quebrando criptografia. Em todos, a falha foi um **pequeno cruzamento** entre o mundo protegido e o mundo comum: um apelido, um trajeto, uma foto, uma impressão. É por isso que OPSEC é, antes de tudo, um hábito de atenção, e não uma lista de programas.



No topo, o comportamento: a parte mais difícil e a que mais falha.

As ferramentas são a base. O comportamento é o que segura o resto.

CAPÍTULO 14

Plano de ação

Ler não protege ninguém. Este capítulo transforma o livro em tarefas, divididas pelo tempo que cada bloco leva. Faça na ordem: o primeiro bloco sozinho já resolve a maior parte dos problemas comuns.

Em 30 minutos (faça hoje)

- [ ] Ativar a **confirmação em duas etapas do WhatsApp**.
- [ ] Ativar **2FA por aplicativo** no e-mail principal.
- [ ] Trocar a senha do e-mail principal por uma **única e longa**.
- [ ] Esconder o conteúdo das **notificações** na tela bloqueada.
- [ ] Combinar com a família a **regra do pedido de dinheiro** (só depois de ligação de voz).
- [ ] Conferir o e-mail no **haveibeenpwned.com**.

Em um fim de semana

- [ ] Instalar um **gerenciador de senhas** e trocar as senhas de banco, redes sociais e lojas.
- [ ] Ativar 2FA em **todas** as contas importantes e guardar os **códigos de recuperação**.
- [ ] Pedir à operadora uma **senha para troca de chip**.

- [ ] Ligar **atualizações automáticas**, **criptografia** e **backup 3-2-1**.
- [ ] Revisar **aplicativos e permissões**.
- [ ] Cadastrar o celular no **Celular Seguro** e anotar o IMEI.
- [ ] Fazer a **investigação sobre si mesmo** e fechar os perfis pessoais.
- [ ] Instalar um **bloqueador de conteúdo** e ativar **DNS seguro**.

Hábitos para sempre

- [ ] Aplicar as **três paradas** em toda mensagem que pede ação.
- [ ] Usar **aliases** em cadastros novos.
- [ ] Postar **depois** de sair do lugar.
- [ ] Revisar contas, dispositivos conectados e permissões **a cada três meses**.
- [ ] Refazer o **modelo de ameaças** quando a vida mudar (emprego novo, exposição pública, separação, mudança de casa).

Se der errado: resposta a incidentes



Diante de um incidente: conter, recuperar, avisar e aprender.

Conta invadida

1. Tente entrar e **trocar a senha** imediatamente. Use “esqueci a senha” se a senha atual não funcionar.
2. **Encerre todas as sessões** (“sair de todos os dispositivos”) e confira o e-mail e o telefone de recuperação: invasores costumam trocá-los.
3. Ative ou refaça o **2FA**.
4. Se não conseguir entrar, use o processo oficial de recuperação da plataforma. **Nunca** pague “especialistas em recuperar contas” que aparecem nos comentários: quase sempre é outro golpe.
5. **Avise seus contatos** por outro canal que a conta foi invadida e que qualquer pedido de dinheiro é falso.

Celular roubado ou perdido

1. De outro aparelho, use o **Buscar iPhone / Encontre Meu Dispositivo** para bloquear e, se necessário, apagar remotamente.
2. Acione o **Celular Seguro** ou ligue para os **bancos** para bloquear os aplicativos.
3. Peça à **operadora** o bloqueio da linha e do IMEI, e um chip novo com o mesmo número.
4. Troque a senha do **e-mail principal** e da conta Apple ou Google.
5. Registre um **boletim de ocorrência**, que é necessário para o bloqueio do IMEI e para o seguro.

Golpe financeiro

1. Ligue **na hora** para o banco e peça o **MED** (no caso de Pix) ou a contestação.
2. Guarde tudo: prints, comprovantes, números, nomes, links.
3. Registre o **boletim de ocorrência**.

Exposição de dados pessoais ou perseguição

1. **Documente** tudo antes de pedir a remoção: prints com data e endereço da página.
2. Peça a remoção à plataforma e, se for o caso, ao Google (Capítulo 7).
3. Revise a segurança física (Capítulo 12) e avise pessoas próximas.
4. Procure a polícia e, se possível, orientação jurídica. Perseguição, divulgação de imagens íntimas sem consentimento e invasão de dispositivo são crimes no Brasil.

Uma última palavra

Segurança perfeita não existe, e quem promete isso está vendendo alguma coisa. O que existe é ser **um alvo pior** do que a média, e isso se consegue com pouca coisa bem feita, mantida com constância. Comece pelos 30 minutos. O resto vem com o tempo.

Glossário

2FA / MFA

Autenticação em dois (ou mais) fatores: exigir uma prova além da senha.

Alias

Endereço de e-mail descartável que encaminha mensagens para o seu e-mail real.

Compartimentalização

Separar atividades e identidades para que o vazamento de uma não atinja as outras.

Credential stuffing

Testar automaticamente senhas vazadas de um site em outros serviços.

Criptografia de ponta a ponta (E2EE)

Só quem envia e quem recebe conseguem ler a mensagem; o servidor no meio não.

DNS

Sistema que traduz nomes de sites em endereços numéricos. Quem responde às consultas vê os sites que você procura.

EXIF

Metadados gravados dentro de fotos: data, aparelho e, às vezes, localização GPS.

Engenharia social

Manipular pessoas para que entreguem informação, dinheiro ou acesso.

Fingerprinting

Identificar um navegador pela combinação única de suas características, mesmo sem cookies.

HTTPS

Versão criptografada da conexão com sites, indicada pelo cadeado.

IMEI

Número de identificação do aparelho celular, usado para bloqueá-lo em caso de roubo.

LGPD

Lei Geral de Proteção de Dados (Lei 13.709/2018), que regula o uso de dados pessoais no Brasil.

MED

Mecanismo Especial de Devolução do Pix, usado para tentar recuperar valores enviados em golpes.

Metadados

Dados sobre os dados: quem, quando, onde, com quem. Revelam padrões mesmo sem o conteúdo.

Modelo de ameaças

Análise de o que proteger, de quem, com que chance e a que custo.

OPSEC

Segurança operacional: identificar e proteger as informações que, juntas, revelam o que deveria ficar protegido.

OSINT

Inteligência de fontes abertas: investigação usando apenas informação pública.

Passkey

Chave de acesso que substitui a senha usando criptografia e a biometria ou o PIN do aparelho.

Phishing

Mensagem falsa que se passa por alguém confiável para roubar dados ou dinheiro.

Ransomware

Vírus que criptografa seus arquivos e pede resgate para devolvê-los.

SIM swap

Golpe em que o criminoso transfere seu número de celular para um chip dele.

Tails

Sistema operacional que roda de um pendrive, usa o Tor e apaga tudo ao desligar.

Tor

Rede que passa sua conexão por três servidores para esconder quem você é do site que acessa.

VPN

Túnel criptografado até um servidor intermediário, que passa a ver o tráfego no lugar do seu provedor.

Segurança perfeita não existe.
Ser um alvo pior do que a média, sim.